IAM HOME LAB PORTFOLIO

Lab 02

RBAC Design, Role Engineering & Access Governance

Opeyemi Ogundimu • IAM Analyst | Identity & Access Management
github.com/okpe027/ https://github.com/okpe027/IAM-HomeLab-Portfolio

Lab	Lab 02 of 20 — Phase 1 (Active Directory & On-Prem Identity)
Completed	April 15, 2026
Environment	VMware Workstation • Windows Server 2022 • Active Directory • Excel
What I did	Designed a formal role matrix, built 14 security groups, provisioned 11 accounts, detected and remediated privilege creep, ran a quarterly access certification
Key finding	Privilege creep on Alex Chen — retained stale Finance Analyst groups after promotion to Finance Manager. Also a SoD violation. Both remediated.
Builds on	Lab 01 (OU structure, Groups, Marcus Williams and Jessica Park accounts)

1. What This Lab Is About

One of the things that separates an IAM analyst from a helpdesk technician is how they think about access. A helpdesk technician processes a ticket and creates an account. An IAM analyst asks: does this person actually need this access? Does giving it to them create a risk? Does it conflict with something else they already have?

This lab is about building that discipline into the lab environment from the ground up. Before I created a single group or user account, I designed a role matrix in Excel. That document became the blueprint for everything I built in Active Directory. Every group name, every user assignment, every SoD control traces back to a deliberate decision in that matrix.

I also ran into — or rather, deliberately created — two of the most common real-world IAM problems you'll encounter in any enterprise: privilege creep and a Segregation of Duties violation. Detecting them, documenting them properly, and remediating them is the kind of work that makes up a significant chunk of an IAM analyst's week.

By the end of this lab I had:

- A formal role inventory mapping 11 distinct roles including a service account
- A production-grade role matrix covering 6 systems across 4 departments
- 14 security groups in AD matching the matrix exactly
- 11 user accounts provisioned with correct group assignments
- A documented SoD policy with regulatory references
- A privilege creep finding detected, documented, and remediated
- A quarterly access certification completed with a compliance summary

2. Why I Started in Excel, Not Active Directory

There's a tendency in lab environments to jump straight into the tool — open AD, start clicking, create things. That approach works fine when you're following a tutorial. It doesn't work when you're trying to build something that holds up to scrutiny.

Real IAM teams design before they build. The role matrix is the design phase. It answers the question — who should have access to what, and why — before a single account or group is created. When an auditor asks you to justify why a Finance Analyst has access to FinanceCore but not PeopleHub, the role matrix is your answer.

> **THE ROLE MATRIX IS THE SINGLE SOURCE OF TRUTH**
> Every group in AD, every user assignment, every permission decision in this lab traces back to a deliberate row in the role matrix. If something isn't in the matrix, it shouldn't be in AD. If it's in AD but not in the matrix, that's an audit finding.
>
> This is how mature IAM programs operate. The matrix isn't documentation that gets written after the fact — it's the authority that drives the implementation.

3. The Role Inventory

Before building the matrix, I identified every distinct role in the FictionalCorp environment. A role isn't just a job title — it's a unique combination of access requirements. If two job titles need identical access, they can share a role. If they need different access, they need different roles.

Role ID	Role Name	Department	Type	Key access characteristic
R001	HR-Manager	HR	Permanent	Full PeopleHub access
R002	HR-Coordinator	HR	Permanent	Standard HR operations
R003	Finance-Manager	Finance	Permanent	FinanceCore + invoice approve oversight
R004	Finance-Analyst	Finance	Permanent	FinanceCore + invoice create only
R005	Finance-Approver	Finance	Permanent	FinanceCore + invoice approve only
R006	IT-Manager	IT	Permanent	Full ITConsole + admin rights
R007	IT-Support	IT	Permanent	ITConsole — no admin rights
R008	IT-Contractor	IT	Contractor	ITConsole read-only — time-limited
R009	Sales-Manager	Sales	Permanent	SalesPro + HR reports read access
R010	Sales-Rep	Sales	Permanent	SalesPro only
R011	Service-Account	N/A	Non-human	App-to-app only — no interactive login

The service account (R011) is worth calling out specifically. Most lab environments skip service accounts entirely. But in real enterprises, service accounts are everywhere — and they're a significant security risk if not properly managed. I gave it its own OU, its own group, and its own documented controls.

4. The Role Matrix

The matrix maps every role to its access across all 6 FictionalCorp systems. Three access levels: Allow, Deny, Read-Only. Every cell is a deliberate decision.

A few things worth noting before looking at the matrix:

- Finance-Manager can approve invoices but not create them. That's a SoD control.
- Finance-Analyst can create invoices but not approve them. Also a SoD control.
- IT-Contractor gets ITConsole read-only — and no email. Contractors don't need a company email.
- Sales-Manager gets read-only access to PeopleHub for headcount reports. Not full HR access.
- Service-Account gets FinanceCore access only, and explicitly cannot log in interactively.

Role	AD	Email	FinanceCore	PeopleHub	SalesPro	ITConsole	Inv.Create	Inv.Approve	Admin
HR-Manager	Allow	Allow	Deny	Allow	Deny	Deny	Deny	Deny	Deny
HR-Coordinator	Allow	Allow	Deny	Allow	Deny	Deny	Deny	Deny	Deny
Finance-Manager	Allow	Allow	Allow	Read-Only	Deny	Deny	Deny	Allow	Deny
Finance-Analyst	Allow	Allow	Allow	Deny	Deny	Deny	Allow	Deny	Deny
Finance-Approver	Allow	Allow	Allow	Deny	Deny	Deny	Deny	Allow	Deny
IT-Manager	Allow	Allow	Deny	Deny	Deny	Allow	Deny	Deny	Allow
IT-Support	Allow	Allow	Deny	Deny	Deny	Allow	Deny	Deny	Deny
IT-Contractor	Allow	Deny	Deny	Deny	Deny	Read-Only	Deny	Deny	Deny
Sales-Manager	Allow	Allow	Deny	Read-Only	Allow	Deny	Deny	Deny	Deny
Sales-Rep	Allow	Allow	Deny	Deny	Allow	Deny	Deny	Deny	Deny
Service-Account	Deny	Deny	Allow	Deny	Deny	Deny	Deny	Deny	Deny

DOCUMENT HEADER ON THE MATRIX

The actual spreadsheet carries a document header: FictionalCorp RBAC Role Matrix v1.0
Owner: IAM Team — Opeyemi Ogundimu | Classification: Internal — Confidential
Review cycle: Quarterly | Last updated: April 15, 2026

That metadata matters. When an auditor asks who owns this document and when it was last reviewed, these fields give you an immediate answer.

5. The SoD Policy

Segregation of Duties is one of those concepts that sounds simple but causes real problems when it's ignored. The principle is this: no single person should be able to both initiate and approve the same transaction. If one person can create an invoice and also approve it, they can authorize fraudulent payments to themselves without any checks in place.

I documented the SoD policy before building anything in AD. Three conflict pairs:

Conflict	Role A	Role B	What goes wrong if combined	Regulatory ref
SOD-001	Finance-Analyst (Invoice Create)	Finance-Approver (Invoice Approve)	One person can create and approve their own invoices — enables fraud	SOX — Section 404
SOD-002	IT-Support	IT-Manager (Admin Rights)	IT Support holding admin rights = privilege escalation risk	ISO 27001 — A.9.2.3
SOD-003	Any human role	Service-Account	Service accounts shared with humans = non-auditable access	NIST SP 800-53 — AC-6

ON EXCEPTIONS

Any SoD exception — like a Finance Manager who needs both roles during an audit period — requires written CISO approval, gets logged in a SoD Exception Register, and is reviewed quarterly. An undocumented exception is an audit finding. A documented one with approval is a controlled risk. There's a big difference between the two.

6. What I Built in Active Directory

Security groups

14 groups across 5 OUs, each one mapping directly to a row in the role matrix. I also created a dedicated Service_Accounts OU at the domain root level to keep service accounts completely separate from human accounts.

Group name	OU	Maps to
GRP-HR-Managers	HR	R001 — HR Manager
GRP-HR-Coordinators	HR	R002 — HR Coordinator
GRP-Finance-Managers	Finance	R003 — Finance Manager
GRP-Finance-Analysts	Finance	R004 — Finance Analyst
GRP-Finance-Approvers	Finance	R005 — Finance Approver
GRP-Finance-InvoiceCreate	Finance	Invoice creation permission
GRP-Finance-InvoiceApprove	Finance	Invoice approval permission
GRP-IT-Managers	IT	R006 — IT Manager
GRP-IT-Support	IT	R007 — IT Support
GRP-IT-Contractors	IT	R008 — IT Contractor

Group name	OU	Maps to
GRP-IT-Admins	IT	Admin rights — IT Manager only
GRP-Sales-Managers	Sales	R009 — Sales Manager
GRP-Sales-Reps	Sales	R010 — Sales Rep
GRP-ServiceAccounts	Service_Accounts	R011 — Service accounts

User accounts

11 accounts provisioned across 4 departments plus 1 service account. Every one logged in the provisioning spreadsheet before creation.

Username	Name	Department	Groups assigned
l.okafor	Linda Okafor	HR	GRP-HR-Managers
p.sharma	Priya Sharma	HR	GRP-HR-Coordinators
a.chen	Alex Chen	Finance	GRP-Finance-Analysts, GRP-Finance-InvoiceCreate
r.thompson	Rachel Thompson	Finance	GRP-Finance-Approvers, GRP-Finance-InvoiceApprove
m.obi	Michael Obi	Finance	GRP-Finance-Managers, GRP-Finance-InvoiceApprove
d.osei	David Osei	IT	GRP-IT-Support (updated — see CHG-0001)
k.nwosu	Karen Nwosu	IT	GRP-IT-Managers, GRP-IT-Admins
m.williams	Marcus Williams	Sales	GRP-Sales-Reps (from Lab 01)
j.adeyemi	James Adeyemi	Sales	GRP-Sales-Managers
f.alhassan	Fatima Al-Hassan	Sales	GRP-Sales-Reps
svc.financecore	FinanceCore App	Service_Accounts	GRP-ServiceAccounts

7. Detecting and Fixing Privilege Creep

Privilege creep is one of the most common security risks in enterprise IAM, and it almost always comes from the same place: a role change where someone adds the new access but forgets to remove the old access. The user ends up with permissions from their previous role on top of their current one, and nobody notices until an audit.

I simulated this with Alex Chen. Three months ago (in this scenario), Alex was promoted from Finance Analyst to Finance Manager. Whoever processed the role change added him to GRP-Finance-Managers — correctly — but never removed him from GRP-Finance-Analysts. They also added GRP-Finance-InvoiceApprove for the manager role but left GRP-Finance-InvoiceCreate from the analyst role in place.

The result: Alex could create invoices AND approve them. That's a CRITICAL SoD violation on top of a HIGH privilege creep finding.

What I found during the access audit

Username	GRP-Finance-Analysts	GRP-Finance-Managers	GRP-Finance-InvoiceCreate	GRP-Finance-InvoiceApprove	SoD violation?
a.chen (BEFORE)	YES	YES	YES	YES	**YES — VIOLATION**
r.thompson	No	No	No	YES	No
m.obi	No	YES	No	YES	No

The formal findings I raised

FINDING AF-001 — PRIVILEGE CREEP (HIGH)
User: Alex Chen (a.chen)
Issue: Retains GRP-Finance-Analysts membership from previous role.
The role change to Finance Manager was incomplete — old groups were never removed.
Risk: User has Finance Analyst permissions on top of Finance Manager permissions.
Action: Remove from GRP-Finance-Analysts and GRP-Finance-InvoiceCreate immediately.

FINDING AF-002 — SOD VIOLATION (CRITICAL)
User: Alex Chen (a.chen)
Issue: Member of both GRP-Finance-InvoiceCreate and GRP-Finance-InvoiceApprove.
This directly violates SoD policy SOD-001 and creates a financial fraud risk.
Regulatory exposure: SOX Section 404.
Action: Remove from GRP-Finance-InvoiceCreate immediately.

What I did to fix it

Removed Alex from GRP-Finance-Analysts and GRP-Finance-InvoiceCreate. He now holds GRP-Finance-Managers and GRP-Finance-InvoiceApprove only — which is correct for his current role as Finance Manager.

Username	GRP-Finance-Analysts	GRP-Finance-Managers	GRP-Finance-InvoiceCreate	GRP-Finance-InvoiceApprove	SoD violation?
a.chen (AFTER)	No	YES	No	YES	**YES — FIXED**

8. Processing a Role Change — CHG-0001

One more thing happened in this lab that's worth documenting: a role change ticket came in for David Osei.

David was an IT Support engineer. Karen Nwosu (IT Manager) had left the organization, and David was being promoted to IT Manager in her place. The ticket authorized adding him to GRP-IT-Managers and GRP-IT-Admins and removing him from GRP-IT-Support.

> **THE CLEAN SWAP PRINCIPLE**
> The most important thing about a role change isn't what you add — it's what you remove. If you only add the new groups without removing the old ones, the person ends up with both their old permissions and their new ones. That's privilege creep by design.
>
> A role change is always a swap: remove the old, add the new, in the same change window. This is what I did for David Osei. GRP-IT-Support removed, GRP-IT-Managers and GRP-IT-Admins added. Clean state.

Action	Group	Result
Removed	GRP-IT-Support	David no longer has IT Support permissions
Added	GRP-IT-Managers	David now has IT Manager access
Added	GRP-IT-Admins	David now has admin rights

9. Running a Quarterly Access Certification

Access certifications are a routine compliance activity that IAM teams run every quarter. The idea is simple: go through every account in the environment, look at what they have access to, and confirm it's still appropriate. If someone changed roles or left, their access should have changed too. The certification is the check that catches anything that slipped through.

I ran a mini certification covering the key accounts in FictionalCorp. Summary:

Username	Current groups	Certification decision	Notes
m.williams	GRP-Sales-Reps	Certify ✓	Active Sales Rep — access appropriate
j.park.contractor	GRP-IT-Contractors	Certify ✓	Contract active — verify expiry date is set

Username	Current groups	Certification decision	Notes
a.chen	GRP-Finance-Managers, GRP-Finance-InvoiceApprove	Certify ✓	Post-remediation — privilege creep resolved
d.osei	GRP-IT-Managers, GRP-IT-Admins	Certify ✓	Post role change CHG-0001 — correct
r.thompson	GRP-Finance-Approvers, GRP-Finance-InvoiceApprove	Certify ✓	Active Finance Approver — appropriate
m.obi	GRP-Finance-Managers, GRP-Finance-InvoiceApprove	Certify ✓	Finance Manager — appropriate
svc.financecore	GRP-ServiceAccounts	Certify ✓	Service account — no interactive login confirmed

Total accounts reviewed: 11 across all departments. Access rights removed: 3 (privilege creep remediation on a.chen). SoD violations found and remediated: 1. Open findings at close: 0.

10. How I Would Talk About This in an Interview

WHEN THEY ASK: HOW DO YOU APPROACH ROLE DESIGN?
I'd say something like this:

Before I touch anything in the system, I build a role matrix. It maps every job function to its permitted systems and resources, and it documents why each access decision was made. I use it to enforce least privilege — so nobody gets access beyond what their job actually requires — and to catch SoD conflicts before they get built into the environment.

In my lab I caught a Finance user who had both invoice creation and approval rights after an incomplete role change. That's a critical SoD violation — one person able to authorize their own payments. I raised it as a formal finding, remediated it by removing the stale groups, and verified the fix. The role matrix was the document that made the violation visible in the first place.

WHEN THEY ASK: WHAT IS PRIVILEGE CREEP AND HOW DO YOU HANDLE IT?
Privilege creep happens when users accumulate permissions over time, usually through role changes where the old access is never cleaned up. In my lab I simulated a Finance Analyst promoted to Finance Manager who still had all their analyst group memberships three months later. I detected it during a routine access audit, raised a formal finding, remediated it by removing the stale groups, and updated the provisioning log with the full change history.

The real fix for privilege creep at scale is a quarterly access certification cycle — a

structured review of every account's access to confirm it still matches their current role.
I ran one at the end of this lab and documented the results.

11. Portfolio Screenshots

These are stored in the Lab02_Portfolio folder and uploaded to GitHub under /Lab02-RBAC-Role-Matrix/Screenshots/.

#	What the screenshot shows	Why I captured it
1	Role matrix — full view with colour coding	The primary RBAC governance document — shows Allow/Deny/Read-Only across all roles
2	SoD policy sheet	Documents the 3 conflict pairs with regulatory references
3	Alex Chen — Member Of before remediation (all 4 groups)	Shows the privilege creep and SoD violation in place
4	Alex Chen — Member Of after remediation (correct 2 groups)	Proves the fix was applied
5	Access audit report showing AF-001 and AF-002	The formal finding documentation
6	David Osei — Member Of after CHG-0001	Shows IT Manager + IT Admins groups post role change
7	AD group structure — Finance and IT OUs expanded	Shows all 14 security groups built in AD
8	Q1 access certification summary	Compliance artifact showing 11 accounts reviewed, 0 open findings

12. What I Produced

Deliverable	Where it lives	Status
Role inventory + role matrix v1.0	/Lab02-RBAC-Role-Matrix/	**Done ✓**
SoD policy document	/Lab02-RBAC-Role-Matrix/	**Done ✓**
Access audit report (AF-001, AF-002)	/Lab02-RBAC-Role-Matrix/	**Done ✓**
Q1 access certification	/Lab02-RBAC-Role-Matrix/	**Done ✓**
Provisioning log (updated)	/Docs/	**Done ✓**
Lab 02 screenshots (x8)	/Lab02-RBAC-Role-Matrix/Screenshots/	**Done ✓**
This documentation	/Lab02-RBAC-Role-Matrix/	**Done ✓**

13. What Comes Next

LAB 03 — EMPLOYEE OFFBOARDING & FULL ACCESS REVOCATION

Lab 03 is where the environment I've built gets tested under pressure. Three termination tickets arrive — a standard voluntary resignation, an urgent for-cause termination with legal hold requirements, and a contractor account expiry — and I have to process all three correctly, quickly, and with a documented audit trail.

It's also where I first encounter the hybrid sync gap — the 30-minute delay between disabling an account in on-premises AD and that disable propagating to Entra ID. Understanding that gap, and knowing how to close it manually, is what separates IAM analysts who understand hybrid environments from those who only know one side.

Opeyemi Ogundimu — IAM Home Lab Portfolio

github.com/okpe027/ https://github.com/okpe027/IAM-HomeLab-Portfolio